



HOXHUNT

How
it
works

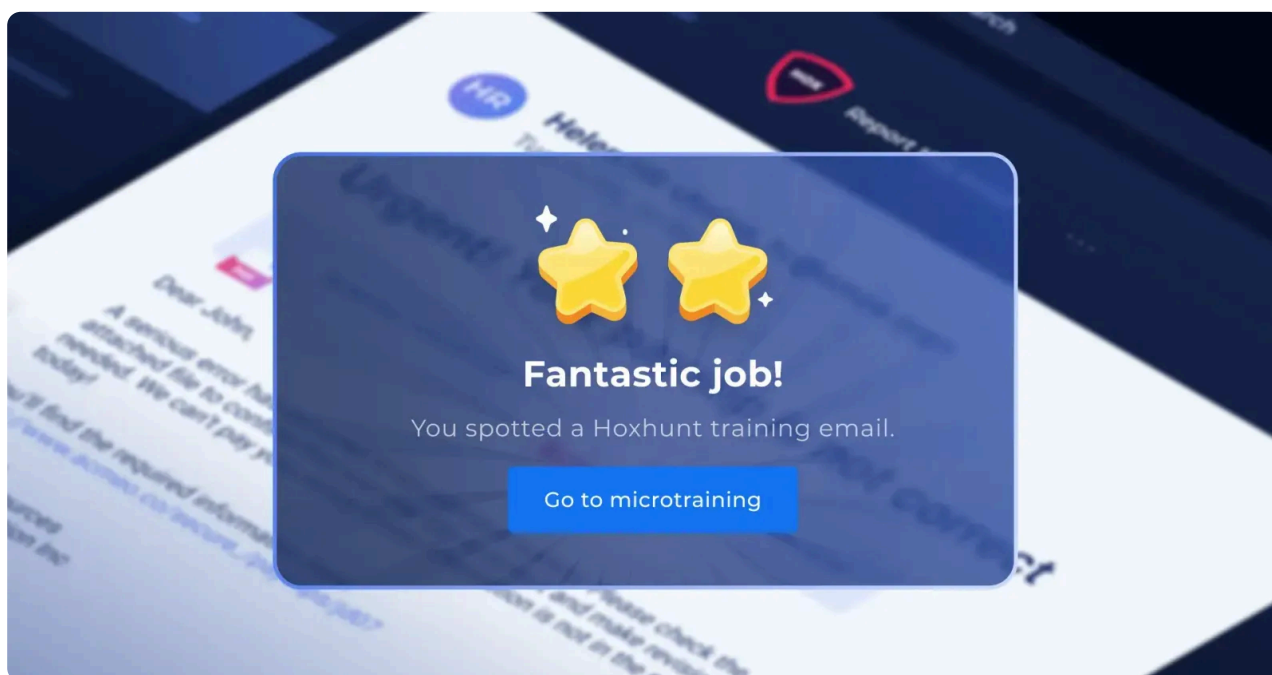
Why Hoxhunt? ▾ Products ▾ Resources ▾ Company [Sign in](#)

[Request demo](#)

Phishing Simulation Best Practices: 2026 Playbook for Real-World Behavior Change

Phishing simulation best practices - ethical lures, instant feedback, and KPIs that drive reporting.

September 9, 2025



Updated **June 29, 2026**

What is a phishing simulation?

A [phishing simulation](#) is a controlled, attacker-style exercise across email (and increasingly SMS/voice/QR) that tests and teaches secure behavior. Strong programs pair every lure with a learning loop: immediate feedback, a concise explainer, and a 1-minute micro-lesson.

Looking to compare vendors? You can read our [phishing simulation tool comparison guide](#) [here](#).

Core elements (and why they matter)

- **Channels & realism:** Go beyond email when appropriate - simulate SMS (smishing), voice (vishing), and QR “quishing” - but scale responsibly to avoid overwhelm and ensure legal compliance across regions.
- **Ethical boundaries:** Favor professional, relevant topics and avoid panic-inducing or highly personal lures (e.g., layoffs, medical results, personal finances). Transparency builds trust and reduces backlash.
- **Payload & “fail method”:** Choose a natural action for the pretext - link, attachment, or in-email form - and route failures to a short teachable landing page with specific tips.
- **OSINT-driven relevance:** Increase believability with safe, contextual cues (industry, location, role), but avoid misuse of internal “inside info.” The goal is realism that teaches, not entraps.
- **Metrics that prove learning:** Track reporting rate, time-to-report, repeat-clicker reduction, and credential-submission rate - then show trend improvements, not just one-off “click rates.” Many leaders value reporting over mere failure percentages.
- **Cadence & culture:** Balance frequency to prevent desensitization (monthly/quarterly is common, we'd recommend minimum monthly), and position simulations as a culture program - *with recognition, gamification, and micro-lessons* - rather than “gotcha” tests.



Featured Takeaway

Phishing simulation best practices focus on **learning over punishment**: calibrate cadence to avoid fatigue, use realistic but ethical lures, deliver **instant, educational feedback**, and track **reporting rate** and **time-to-report** - not just clicks. Integrate simulations with micro-training and culture programs so employees feel like partners, not targets.

Design best practices (cadence, fatigue, comms)

Start with a monthly baseline; layer risk-based micro-drills for high-exposure roles and new hires. Tune with reporting rate and time-to-report; refresh content before increasing volume; pause/soften during sensitive periods.

Phishing Simulation Cadence Planner			
Audience / trigger	Starting cadence	Why it works	When to adjust
Company-wide baseline	Monthly or quarterly	Reinforces recognition without alert fatigue; keeps habits alive between real incidents.	If engagement dips, refresh themes/personali before adding volume.
High-risk roles (finance, IT, exec support)	Every 1-4 weeks (short micro-drills)	Higher exposure justifies tighter reps; micro-format minimizes disruption.	Tune by <i>reporting rate</i> and <i>time-to-report</i> ; reduce if false positives or workload spikes.
New hires / returners	Warm “welcome” benchmark (after initial training), then 30/60/90-day touchpoints	Builds trust early and avoids “cold” gotchas; adaptive difficulty prevents overwhelm.	Delay/soften during intense onboarding windows or feedback-flagged stress.
Repeat clickers	Weekly micro-sims + individual coaching	Practice helps, but change sticks with supportive, 1:1 guidance—not punishment.	As the cohort shrinks, taper to monthly; escalate to manager check-ins only if patterns persist.
After incidents / new attack	Focused follow-up	Converts lessons learned into muscle	Don’t stack too many vectors

Audience / trigger	Starting cadence	Why it works	When to adjust
patterns	drills in the next cycle	memory; mirrors real-world threats (QR/MFA fatigue/vishing).	at once; prioritize relevance over volume.
Sensitive periods (layoffs, restructures, crises)	Pause or soften campaign	Protects psychological safety and trust; avoids backlash from “cruel realism.”	Resume with transparent comms and gentle difficulty ramp.
Tuning rules: • Measure to manage - use <i>reporting rate</i> and <i>time-to-report</i> as your cadence dials; click rate alone plateaus. • Refresh > repeat - if engagement dips, update themes and personalize before increasing frequency. • Expect a short-term spike in reports after campaigns; calibrate rather than over-correct. • Prevent auto-click misfires - whitelist/bypass link-scanners to avoid false “fails” and mass remedials.			

Tuning rules that prevent fatigue

- **Measure to manage.** Optimize cadence with reporting rate and time-to-report - click rate alone plateaus and can harm psychological safety.
- **Refresh > repeat.** If engagement stalls, change themes and personalize; cadence issues often mask repetition fatigue, not “too many emails.”
- **Protect trust windows.** During layoffs, restructures, or tense periods, pause or soften campaigns to avoid backlash and keep safety intact.
- **Start easy, scale smart.** Open with a welcome benchmark and let difficulty adapt per user so no one feels tricked or bored.
- **Expect (and interpret) spikes.** A short-term surge in reporting can be a good sign -calibrate rather than over-correct.
- **Avoid automated misfires.** Security tools can “auto-click” links and enroll everyone in remedials; verify logs and workflows before big sends.

How do you create psychological safety?

Build simulations that reward reporting, not punish mistakes. Normalize slips, give instant feedback when people report, and make reporting effortless (one button, no hunting). Use positive reinforcement and light gamification to sustain motivation, and coach repeat clickers individually. Treat adults like peers - relevance and respect beat fear every time.

Design moves that increase safety

- **Define the win as “reporting.”** Click rate never hits zero and over-focusing on it hurts psychological safety; reporting rate keeps improving and reflects real culture change.
- **Remove friction to speak up.** Give people a single, obvious report phish button and close the loop with instant feedback so they feel helped, not judged.
- **Reinforce positives, immediately.** Small “wins” (thank-you notes, stars, streaks, leaderboards) create momentum and keep engagement high without feeling juvenile.
- **Start easy, build confidence.** Open with an easy first simulation and tell people exactly how to succeed; then increase difficulty per person to keep challenge fair.
- **Treat adults like peers.** Center empathy and relevance; speak the language of each role and avoid “school-like” scolding - adults change through timing, trust, and usefulness.
- **Coach repeat clickers - don’t punish.** Shrink the cohort with broadly effective training, then segment and coach individuals with context that fits their role or region.
- **Make amnesty explicit.** Say (and show) that if someone slips on a real phish, the right move is to report fast - fear of punishment delays escalation.

Psychological Safety - Do & Don’t

Do

Define the win as “reporting.” Tell people success = reporting suspicious messages.

Give instant, kind feedback. Close the loop when users report - what was phishy and why.

Make reporting effortless. One obvious “Report phish” button; no hunting through menus.

Start easy, then adapt. Open with a welcoming first sim; ramp difficulty per user.

Use positive reinforcement. Stars, streaks, shout-outs - light gamification, never juvenile.

Coach repeat clickers 1:1. Understand context (role, workload) and set micro-tasks.

Protect trust windows. Pause/soften during layoffs, crises, or peak deadlines.

Don't

Don't punish or shame. Fear reduces reporting and slows real-incident escalation.

Don't over-index on click rate. It never hits zero- optimize for reporting and time-to-report.

Don't run "cold gotchas." Avoid surprise tests for new hires or during sensitive periods.

Don't use creepy lures. Skip highly personal/panic topics (medical, layoffs, finances).

Don't assign hour-long remedials. Use short, contextual micro-lessons instead.

Don't ignore tooling artifacts. Prevent auto-click/URL-rewrite false "fails" before launch.

North star: build a culture where people *report fast* - that protects the org more than chasing zero clicks.

What makes a simulation realistic and ethical?

Aim for real but responsible. Use believable pretexts aligned to roles and channels (email, SMS, voice), but avoid panic-inducing or highly personal lures. Keep exercises short, disclose purpose at program level, and match the "fail action" to the scenario. Train deepfakes/vishing safely - realism should teach, not traumatize.

Realism now means accounting for AI: AI-generated phishing surged roughly 14× at the end of 2025 — from under 5% to 56% of detected attacks in a single month ([Hoxhunt Phishing Trends Report 2026](#)). Simulations that still look like last year's templates train people for attacks that have already evolved.

Reality that teaches (not tricks)

- **Role-aligned pretexts.** Choose scenarios people actually face (IT reset, finance urgency, exec impersonation); these are the most common (and effective) real-world hooks.
- **Multi-channel where relevant.** Modern attacks chain email + phone; simulate vishing and deepfake voice carefully to build

recognition without overreach.

- **Match the end goal.** If the pretext is a payment request, the “fail” is acting on the instruction, not clicking - design the path to reflect how attacks actually land.

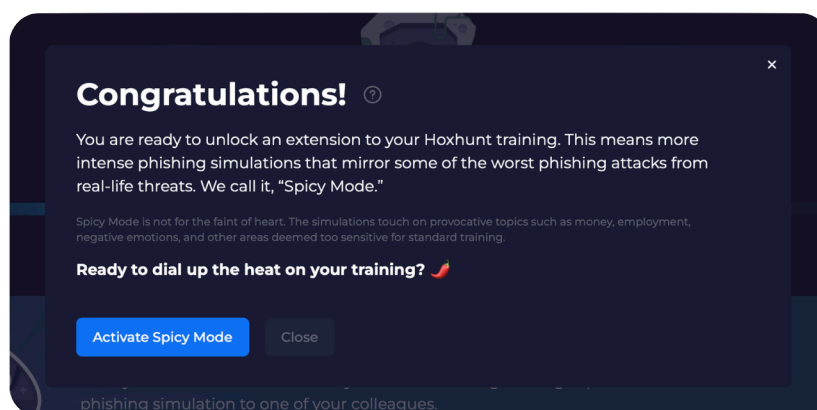
Ethical guardrails (program-level)

- **Real but responsible.** Don't recreate the worst incidents or let simulations drag on; respect time and stop before it feels like entrapment.
- **Avoid “cruel realism.”** Steer clear of layoffs, medical results, or personal-finance scares; the consensus is challenge, don't harm - keep topics professional and relevant.
- **Be transparent + legal.** Announce that periodic tests occur; check regional limits (SMS/phone spoofing can cross telecom lines). Coordinate with Legal/HR for consent and data-handling expectations.

Design details that keep trust

- **Use familiar context—safely.** Reference tools, logos, and workflows employees already use, but avoid exploiting sensitive inside information.
- **Keep it short.** End the scenario early - especially for roles like sales - so people don't waste cycles chasing a fake lead.
- **Teach caller-ID skepticism.** Explain how spoofed numbers and internal extensions amplify trust; give a verify-and-call-back process.

Rule of thumb: You don't train soldiers in real firefights. Make it feel real, then close with reflection and reinforcement.



Hoxhunt gives users the option to opt-in to more advanced phishing simulations once they reach a certain level via our Spicy

Which scenarios should you prioritize in 2025?

Prioritize simulations that mirror today's phishing attacks:

business email compromise (BEC), credential harvesters with realistic landing pages, QR "quishing," MFA-fatigue, SMS phishing, and voice phishing (vishing) - often chained in multi-channel pretexts. Match the fail action to the story (click, open attachment, act on a request).

Top scenarios to cover (with design notes)

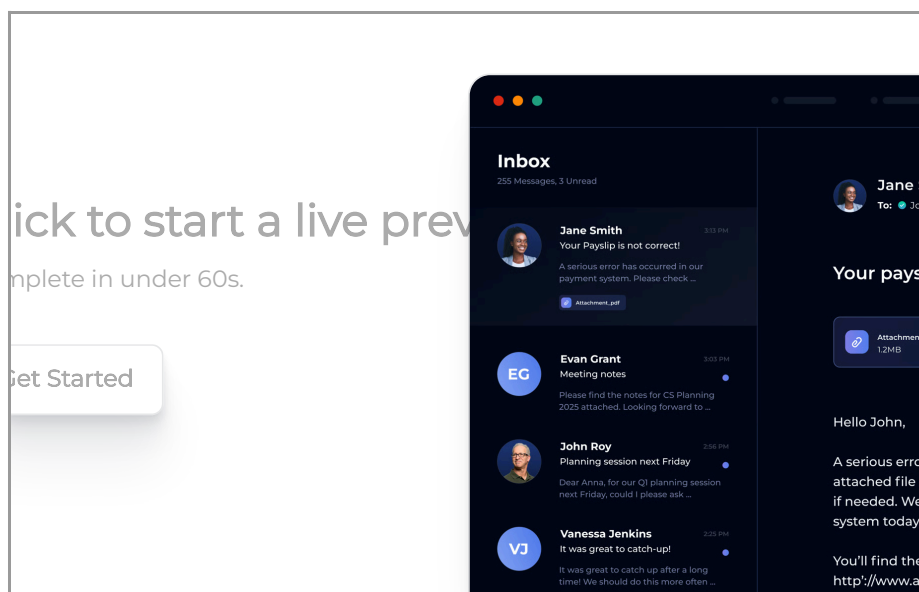
- **Business Email Compromise (invoice fraud, payroll diversion):** Channel: email → voice calls or chat follow-up. Fail = acting (e.g., paying a bogus invoice), not just clicking a phishing link. Teach verify-and-call-back procedures.
- **Credential-harvesters (cloud/app logins):** Use convincing phish landing pages (custom landing pages tied to the pretext) and short micro-learning after failure. Measure credential-submission rate and time-to-report.
- **QR "quishing":** Whitelist scanners to avoid false "auto-clicks" from integrated cloud email security. Track reporting, not just clicks.
- **MFA-fatigue:** Simulate rapid MFA prompts and teach "deny + report" behavior. Keep the exercise short to protect morale.
- **SMS phishing (smishing):** Delivery/bank/update pretexts that drive to mobile phishing websites. Verify regional rules before running SMS tests.
- **Voice phishing (vishing) and deepfake calls:** Model the email + spoofed call flow. Teach caller-ID skepticism and safe incident response ("hang up and verify"). Use responsibly -keep it brief and debrief fast.
- **Attachment-based lures (malicious emails):** Where the story fits (e.g., "Updated HR policy"), make the fail action opening a phishing attachment rather than clicking. Follow with an Oops landing page.

Build each scenario so it feels real (but responsible)

- **Match channel + fail method to the story.** If the lure is a wire transfer, the fail is complying; if it's an account warning, the fail is entering credentials on a landing page.

- **Use multi-channel pretexts sparingly.** Attackers now chain email + phone with OSINT; simulate this pattern to raise recognition - but avoid overwhelm.
- **Keep lures professional.** Avoid panic-bait (layoffs, medical, personal finance). Realism should teach, not “gotcha.”
- **Use current templates and tools.** Rotate phishing templates (including QR and AI-crafted lures). Many programs supplement with phishing simulation software like [Microsoft Defender Attack Simulator](#) or [Hoxhunt](#)- just whitelist scanners first.

Below you can see what Hoxhunt's phishing simulations look like for users.



How do you choose the “fail method” and design the landing page?

Start with the attacker’s objective, then pick the natural fail method - click a phishing link, open a phishing attachment, submit credentials on a landing page, or act on a request (e.g., BEC). Pair every simulated phishing failure with an instant, teachable landing page and micro-lesson, track credential-submission and time-to-report, and prevent scanner auto-click misfires.

Decision rule (works across channels)

Objective → Pretext → Fail method → Teaching moment. Real attacks have “something after the click.” Make your victim flow coherent and educational - then close with a concise Oops, that was a phish page and a micro-learning module.

Fail Method & Landing Page Matrix

Objective (social engineering)	Natural fail method	What your landing page teaches	Notes / security tools
Credential compromise attacks (account warning, SSO reset)	Enter credentials on a spoofed phish landing page	3 cues (URL, sender, urgency), safe next steps, where the <i>Report phishing</i> button lives	Rotate <i>phishing templates</i> ; keep content current if using Microsoft Defender Attack Simulator
Business email compromise (invoice fraud, payroll diversion)	Act on the request (approve payment / change IBAN)	Verified callback + dual-approval habit; how to escalate quickly	Treat “fail” as <i>action</i> , not click; keep copy professional
Attachment lures (policy update, delivery note)	Open a phishing attachment (PDF/Doc)	File hygiene (macros, extensions), preview safely, when to report	Use when the story fits; don’t overuse attachments
QR / mobile drive-by (“quishing”)	Scan code → mobile phishing website	Mobile URL scrutiny, app-store imposters, how to report from phone	Whitelist link-scanners to prevent false “auto-click” fails
MFA-fatigue (push bombing)	Approve repeated prompts	Deny-and-report behavior; device hygiene basics	Keep drills brief to protect morale
Vishing / hybrid (email + spoofed voice call)	Comply on the phone (share info / approve action)	Caller-ID skepticism; verified callback script; short debrief	Use sparingly; debrief fast to avoid overreach

Landing-page & micro-lesson checklist

- **Immediate feedback, not scolding.** Short explainer + one-minute micro-learning modules; then back to work.
- **Actionable next steps.** “Report it, then delete” - and show where the Outlook toolbar / report phishing button lives.
- **Positive reinforcement notifications.** Thank-you copy and progress cues boost employee morale and engagement.
- **Measure what matters.** Track credential-submission rate, time-to-report, and repeat-clickers - not just click rate. Feed results into training campaigns.

How do you tailor phishing simulations to your business?

Tailor phishing simulation to your risk: map likely phishing attacks to roles/regions, localize language, and use adaptive difficulty so each person sees believable simulated phishing - without crossing ethical lines. Make reporting effortless (one button), deliver instant feedback, and integrate signals from your SOC so training campaigns reflect real incidents.

Map attack surface → role-based scenarios

- **Finance:** BEC, vendor IBAN changes, invoice updates → design attack simulations where the “fail” is acting on the request; measure time-to-report.
- **IT / admins:** SSO resets, password check required immediately, endpoint compromise attacks; prefer credential-harvest flows and phish landing pages that teach URL checks.
- **Exec support / HR:** business email compromise attacks, meeting changes, sensitive file shares; train out-of-band verification (call-back).

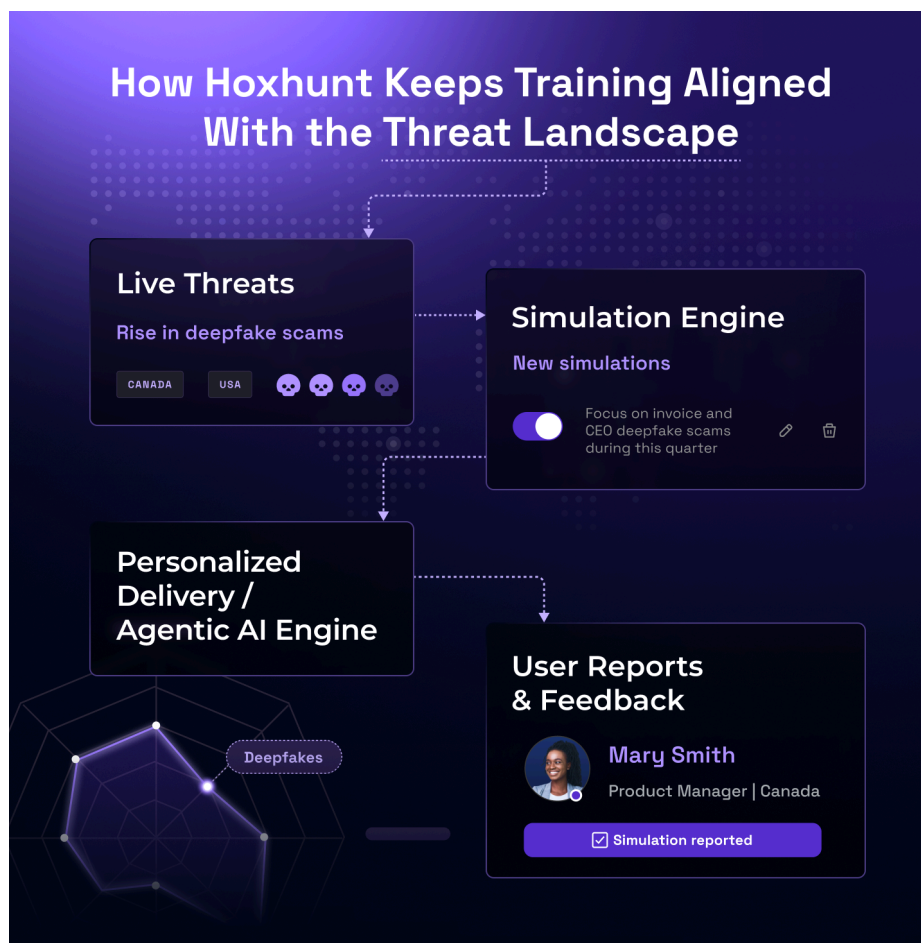
Personalize content, not creepiness

- **Adaptive difficulty by person/role.** Programs that tune challenge to skill and risk keep people engaged and learning.
- **Positive reinforcement + instant feedback.** Stars, streaks, and “thanks for reporting” nudges sustain employee engagement and user security awareness - especially when someone spots a real phish.
- **Make reporting effortless.** Surface a single report phishing button (e.g., Outlook toolbar) and close the loop fast so people feel helped, not judged.

Wire simulations into your security stack

- **Integrate with security tools.** Trigger just-in-time nudges; connect dashboards to your [security operations center](#).
- **Prevent false fails.** Some integrated cloud email security tools rewrite URLs (e.g., QR tests showing “1000% opens”). Whitelist/bypass to avoid noise.
- **Use real-threat intel.** Build scenarios from reported cyber threats (smishing, QR, credential harvesters) so simulated phishing attacks mirror what lands in inboxes.

Below you can see how we turn real reported threats into phishing simulations here at Hoxhunt.



What metrics actually prove behavior change?

Prioritize reporting rate and time-to-report over raw click rate. Track real-threat reporting (not just simulated phishing) to show culture change and SOC impact. Clicks plateau; reporting trends keep climbing when programs use positive feedback and timely micro-lessons.

The proof is in real-threat reporting over time: in Hoxhunt's 2026 dataset, real-threat detection climbs from 13% to 71% across the training curve ([Hoxhunt Phishing Trends Report 2026](#), pp. 37–39) — the kind of sustained climb clicks alone never show.

Your KPI short-list (definitions → why it matters → how to measure)

Reporting rate (simulated & real)

- What: % of users who report suspicious messages.
- Why: Reflects culture and improves incident response speed.
- Measure: Per campaign and monthly trend; aim for continuous lift, not a fixed “good” number.

Time-to-report

- What: Minutes from open/interaction to user report.
- Why: Faster escalation limits damage from cyber attacks and phishing incidents.
- Measure: Median by role/team and channel (email, SMS phishing, voice phishing).

Repeat-clicker reduction

- What: % decrease in users failing twice+ across training campaigns.
- Why: Demonstrates targeted coaching impact; prevents shaming and improves employee morale.
- Measure: cohort size over rolling 90 days.

Why not “click rate” as your north star? It never hits zero and over-focusing on failure erodes psychological safety; reporting keeps improving with positive reinforcement.

How should you handle repeat clickers constructively?

Treat repeat clickers as a signal to coach, not punish. First, check whether your training approach encourages reporting and learning. Then shrink the cohort with positive reinforcement, micro-lessons, and role-relevant scenarios. Finally, work 1:1 to understand motivations and remove blockers. Punitive programs backfire - they suppress reporting, damage morale, and erode culture.

We unpacked one of cybersecurity’s most polarizing dilemmas: what should be done with repeat offenders in phishing simulations in a recent episode of the [All Things Human Risk Management Podcast](#).



What Happens When Users Keep Failing? And Should We Puni

Jun 29 · All Things Human Risk Management

Save on Spotify

49:43

Playbook for dealing with repeat clickers

- **Fix the program before the people.** If engagement is low or users fear “gotchas,” overhaul the security awareness training so success = reporting and feedback is instant.
- **Use positive reinforcement, not penalties.** Reward correct actions (reports), pair misses with short micro-learning, and keep tone respectful - this sustains behavior change better than reprimands.
- **Shrink the cohort, then individualize.** As numbers drop, switch to 1:1 outreach: understand *why* they click (overload, curiosity, unclear processes), and set small, specific goals.
- **Coach with empathy and relevance.** Tie examples to their role; show how quick reporting limits damage even after a mistake. Make “report fast” the default reflex.
- **Leverage curious clickers.** Some fail from *interest*, not negligence - offer a safe sandbox and turn them into peer champions instead of risks.
- **Keep HR as a culture partner, not an enforcer.** Use HR to build psychological safety and craft humane comms; don’t route routine failures to disciplinary tracks.

Why this works: Positive, individualized coaching changes attitudes and actions; punitive “consequences” often create fear, under-reporting, and productivity drag (people avoid email altogether).

What legal, privacy, and ethics guardrails should you follow?

Announce that periodic exercises occur (no spoilers), keep lures professional, and clear regional telecom rules before SMS/phone tests. Don’t spoof real external numbers; coordinate with Legal/HR on consent and data handling. Treat mistakes as teachable moments - punitive programs suppress reporting.

At-a-glance guardrails

- **Announce the program (without spoilers).** Tell employees that simulated phishing and other attack simulations may occur to support cybersecurity awareness training (the aim is learning, not entrapment).
- **Keep lures professional and non-harmful.** Skip highly personal or panic topics (layoffs, medical results, personal finances). These erode trust and invite complaints.
- **Check regional telecom rules for SMS/phone.** In some countries, simulating calls/texts can breach regulations; consult Legal/HR, avoid spoofing real numbers, and exclude sensitive groups if needed.
- **Design for dignity.** Treat mistakes as teachable moments; punitive programs fuel grievances and suppress reporting - bad for incident response and culture.

Program communications you can copy

- **Plain-English program notice (pre-launch):** “We run periodic security exercises to help everyone spot phishing attempts and protect data. These are part of our cyber security program. If you’re ever unsure - report it. We’ll always provide quick feedback so we can learn together.”
- **Scope note for multi-channel tests:** “From time to time, exercises may include email, QR, text, or phone-based social engineering. We design them to be realistic but respectful and follow local rules.”

Red lines (don’t cross)

- **No cruel realism.** Fake layoffs/medical/personal-finance are broadly viewed as off-limits; they damage employee morale and security posture.
- **No “cold gotchas” for new hires.** Educate first; surprise testing can create a hostile first impression of security.
- **No spoofing of real external identities/numbers.** Use safe stand-ins; legal peers flag telecom/privacy risk in several regions.

“Click rate never goes down to zero... and focusing on click rates means we focus on failure. That can be really damaging to psychological safety - people become afraid to report mistakes.” -
[Maxime Cartier](#) (Head of Human Risk, Hoxhunt)

Phishing simulation best practices (Top 10)

Design phishing simulation as a safe, realistic learning loop: run a monthly/quarterly baseline, mirror real phishing attacks, match the fail method to the story, and give instant feedback. Optimize for reporting rate

and time-to-report, not “zero clicks,” and fix tooling (one report button, scanner whitelists) to keep data clean.

1. **Make reporting the win condition:** Clicks won't hit zero; over-focusing on them damages psychological safety. Track reporting rate and time-to-report as your north-star metrics.
2. **Cadence without fatigue:** Use a monthly baseline; increase frequency only for high-risk cohorts and new hires - refresh content before you add volume.
3. **Realistic, ethical scenarios.:** Prioritize BEC, credential harvesters and SMS phishing. Avoid panic-bait (layoffs/medical/personal finance). Keep exercises short and respectful.
4. **Match the fail method to the pretext.:** If the pretext is payroll change (BEC), the fail is acting; if it's an account warning, it's submitting credentials. Follow every failure with a one-minute micro-lesson.
5. **Fix the plumbing before the program:** Unify to one report phishing button (e.g., Outlook add-in) and whitelist URL rewriters; QR tests often break from Microsoft link rewriting, skewing results.
6. **Instant feedback beats hour-long remedials:** Route simulated failures and real reports to concise, positive landing pages that explain the social engineering cues and next steps; morale and learning both improve.
7. **Adaptive difficulty and fresh templates:** Rotate phishing templates from current intel; tune challenge per user/role. That's how you avoid plateaus and “template fatigue.”
8. **Train multi-channel safely (email + phone + SMS):** Simulate voice calls and SMS thoughtfully - especially deepfake-style vishing for exec support - then debrief fast to protect trust.
9. **Integrate with your SOC & Microsoft stack:** Feed reports into the security operations center, trigger just-in-time nudges from Microsoft Defender/EDR, and export metrics leaders care about.
10. **Communicate transparently and measure culture:** Announce that periodic simulated phishing attacks support cybersecurity awareness training; expect a short-term reporting spike (good) and tune over time. Link outcomes to fewer incidents and faster response, not just lower click rates.

Learn how to design phishing simulations that build trust, boost engagement, and strengthen your organization's security culture. In this video, we walk through the essentials - from creating realistic, fair scenarios to reinforcing psychological safety and delivering instant feedback.



Design Effective Phishing Simulations

Hoxhunt



Watch on

Year-one rollout: cadence, difficulty ramp, and sample calendar

Q1 - Foundations (build trust)

- Program comms: simulations support cybersecurity awareness training - success = reporting.
- Deploy a single report phishing button (e.g., Outlook) and instant feedback.
- Baseline send (easy simulated phishing) + 1-min micro-lesson.
- Check integrated cloud email security (QR/URL rewrites) and whitelist to prevent auto-click noise.

Q2 - Calibrate by risk (adaptive difficulty)

- Move high-risk roles (finance, IT, exec support) to tighter micro-drills; everyone else stays at same cadence.
- Rotate phishing templates (BEC, invoice change, delivery updates).

Q3 - Multi-channel realism (responsibly)

- Add QR ([quishing](#)) and [SMS phishing](#) for appropriate teams; verify regional rules and keep lures professional.
- Pilot [voice phishing](#) for exec support (brief, debrief fast).
- Coach repeat clickers 1:1 with positive reinforcement - not penalties.

Q4 - Prove impact and harden operations

- Tie signals to incident response dashboards; highlight reporting rate/time-to-report gains.
- Tune training campaigns; plan next year’s scenarios and ramp.

Templates & topics: what should you try vs avoid?

Use professional, realistic phishing templates tied to real cyber attacks being used in the wild and avoid panic-bait lures. Keep training positive, rotate content, and respect timing (e.g., during reorganizations). Transparency and positive reinforcement prevent backlash and improve reporting.

Training techniques (micro-lessons, gamification, adaptive difficulty)

- **Instant feedback > hour-long remedials:** A short landing page + 1-minute micro-lesson changes behavior faster.
- **Positive reinforcement:** Stars, streaks, and quick “thanks for reporting” nudges sustain engagement.
- **Adaptive difficulty:** Ramp per user/role to keep challenge fair and avoid plateaus.
- **Coach repeat clickers 1:1:** Shrink the cohort with better program design; then personalize with empathy.

Templates & Topics - Try vs Avoid			
Use these (safe + effective)	Why they work	Avoid / caution	Why to avoid
Business email compromise (vendor IBAN change, invoice update)	Mirrors real losses; teaches verify-and-callback and out-of-band checks.	Layoffs / medical results / personal-finance bait	Erodes psychological safety; drives complaints and under-reporting.
Credential notices (SSO/session reset → phish landing page). Ex: “Password	Natural fail is credential submission; perfect for concise landing-page coaching.	Salary/bonus rumor lures	Feels manipulative and personal; harms trust.

Use these (safe + effective)	Why they work	Avoid / caution	Why to avoid
Check Required Immediately”			
Delivery / meeting / policy update nudges. Ex: “Travel Perks”, “Google Play” receipt, “Canvas Teacher” invite	Everyday pretexts build the report-button habit without drama.	Perks/benefits lures during tense periods	Context clash during reorganizations appears tone-deaf.
QR (“quishing”) → mobile phishing website	Matches current attacker tactics; trains mobile URL scrutiny.	Spoofing real external identities/numbers (SMS/phone)	Telecom/privacy risk; requires strict controls and approvals.
SMS phishing (delivery/bank) where regionally permitted	Expands channel coverage; short micro-lessons land well.	All-channels-at-once blitzes	Overwhelms users; increases false positives.
Vishing (exec support; verify-and-callback drills)	Prepares for deepfake/voice-led BEC chains; high salience when brief + debriefed.	Punitive comms or public shaming of “clickers”	Suppresses reporting; damages morale and culture.
Tip: Keep lures professional; match pretext → fail method → teachable landing page. Rotate templates; don’t run panic-bait.			

What’s the right platform and tooling stack?

Minimum viable: Defender Attack Simulation + followup training moments + single report button + basic metrics.

Advanced: Dedicated platform with multi-channel lures (SMS/voice), adaptive AI-driven playbooks, SOC integrations, and automated reporting exercises tied to real-life cyber threats.

Selection criteria (what actually matters)

- **Realism & channels:** High-fidelity email phishing templates, phishing websites/landing pages, phishing attachments, and optional voice calls/SMS for multi-channel attack simulations.
- **Learning loop:** Instant, teachable landing page with micro-learning modules; Positive reinforcement notifications after reports to lift employee engagement and morale.
- **Analytics that prove change:** Built-in tracking for reporting rate, time-to-report, credential-submission, repeat-clicker trend, plus export to your security operations center (SIEM/SOAR).
- **Deliverability & safety:** Plays nicely with integrated cloud email security; supports URL-rewrite bypass to prevent scanner auto-clicks.
- **Scale & localization:** Multi-language content, role/region targeting, AI-driven playbooks/machine learning to adapt difficulty and rotate content.

Why choose Hoxhunt for phishing simulations?

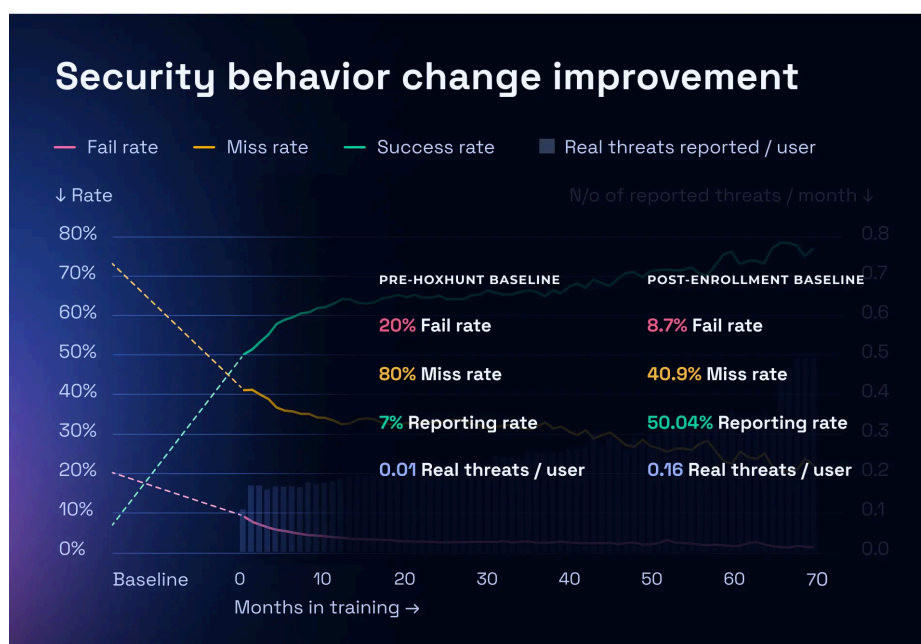
Hoxhunt excels at adaptive, gamified phishing simulation that lifts reporting and eases SOC workload. It unifies the report phishing button, gives instant feedback on real phish, rotates content from current threats, integrates with Microsoft/EDR signals, and prioritizes psychological safety with an easy “welcome” benchmark and per-user difficulty.

What buyers told us (and how Hoxhunt answers)

- **“Training feels generic; engagement is low.”** Hoxhunt personalizes simulated phishing difficulty to each user’s skill/role and uses stars, streaks, leaderboards to sustain motivation. Result: higher participation in security awareness training without “gotcha” vibes.
- **“We only see click/fail rates.”** Admins get real-time dashboards and user-level insights that go beyond clicks, plus threat heatmaps you can act on in training campaigns.
- **“Too many places to report a phish.”** Hoxhunt consolidates to one integrated button (Outlook/Gmail), eliminating the “which tool do I use?” confusion and increasing reliable reporting exercises.
- **“Employees never get feedback on real phishing incidents.”** The platform provides instant, automated feedback on real reports - teaching in-flow and reducing back-and-forth with the SOC.
- **“Microsoft integration and deliverability are a mess.”** Hoxhunt is designed to seamlessly integrate with Microsoft Defender/EDR signals for behavior-based training.

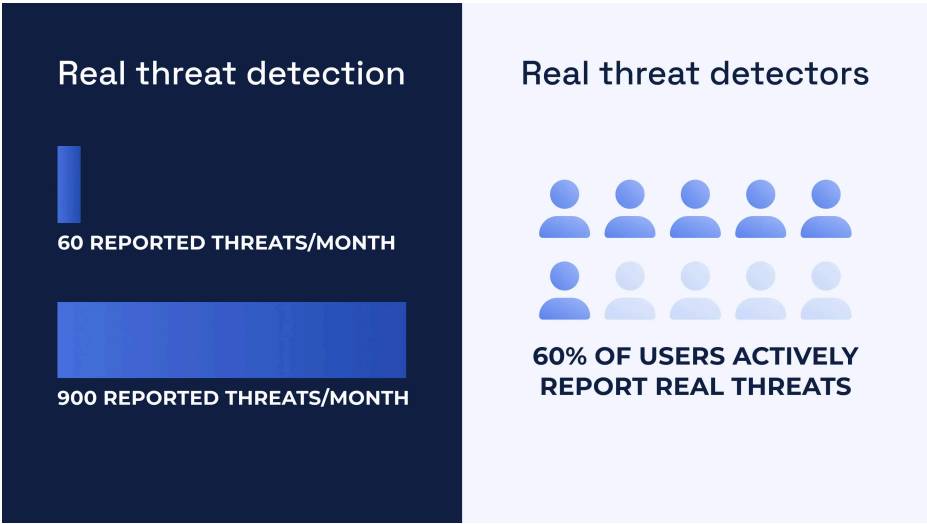
Differentiators that matter in 2025

- **Psychological-safety by design.** A welcome benchmark and adaptive difficulty keep users challenged - but not overwhelmed - while reinforcing “report fast” behavior.
- **Threat-led content rotation.** Templates are updated from real-life phishing attacks (QR, credential harvesters, smishing), so attack simulations mirror today’s cyber threats.
- **Vishing/deepfake training capability.** Hoxhunt offers deepfake simulations to prepare for business email compromise chains that pivot to phone/Teams.
- **Culture over punishment.** Our approach aligns with expert guidance that punitive programs backfire and suppress reporting - so the platform emphasizes positive reinforcement and short micro-lessons instead.



Case Study: Bird & Bird transforms human cyber risk with Hoxhunt

Overview: Bird & Bird, a global law firm founded in 1846 and headquartered in London, spans 20 countries with around 3,300 attorneys and staff. Serving clients in sensitive sectors - especially finance - it's a high-value target for cyber threats.



The Challenge: Building trust, not fear

- The firm needed to shift away from punishment-driven security awareness training models that demoralize users and suppress reporting.
- They wanted real behavior change, measurable risk reduction, and a people-first experience that users would embrace rather than resent.

The Hoxhunt Solution

- Hoxhunt’s human risk management platform was a natural fit: individualized micro-trainings, gamified engagement (stars, leaderboards), adaptive difficulty, and instant feedback loops encouraged active learning - not just passive awareness.
- Leadership embraced it, noting rare positive sentiment

Case Study - Bird & Bird Outcomes with Hoxhunt			
Metric	Before	After	Change
Real threat detection	60 reports/month	900 reports/month	+1,400%
Resilience ratio (success-to-failure)	5.3	37.8	+613%
Failure rate	9%	1.8%	−80%
Miss rate	43%	28.8%	−33%
Real threat detectors	—	60% of users reported at least one real threat	—

Metric	Before	After	Change
Reporting time	—	6 h 35 min average	—

US benchmark: The same realism-plus-volume approach scales in the United States. [Copart](#), the Dallas-based global vehicle remarketer, ran 202,992 completed phishing simulations across 963 unique variants and doubled its reporting rate from 24% to over 50%, after moving on from a legacy cadence of one to three campaigns per quarter. A high-variety simulation library is what lets a US enterprise and an EU firm like Bird & Bird both sustain that climb.

Phishing simulation best practices FAQ

How do I run my first simulation?

Start with a low-friction template, target a pilot cohort, and schedule one campaign per week for the first month. Measure report-rate and time-to-report.

Can I use Microsoft 365 AST for best practices?

Yes - follow the same cohort and frequency logic. If you need automated coaching or gamification, consider switching to Hoxhunt.

What’s a “good” click rate?

Click rate never hits zero and over-focusing on it hurts psychological safety. Optimize for reporting rate and time-to-report - those correlate with faster detection and fewer incidents.

Should we tell employees about simulations?

Yes - announce that periodic simulated phishing attacks support learning. Keep lures professional and avoid panic-bait; transparency builds trust and reduces backlash.

Do we punish repeat clickers?

No. Punishment suppresses reporting and damages culture. Use positive reinforcement, micro-lessons, and 1:1 coaching to address root causes.

How realistic should scenarios be?

Mirror real phishing attempts but avoid highly personal or panic topics. Keep exercises short and respectful.

Is it OK to run “gotcha” tests without telling employees?

Program-level transparency works better. Announce that periodic simulated phishing attacks support learning, and avoid cold gotchas - especially for new hires. You'll protect trust and get better reporting behavior.

What's the right way to onboard new hires?

Use a warm onramp: quick primer, an easy first simulation, instant feedback, and clear success criteria (reporting). Skip surprise tests; ramp difficulty per person after they've seen the basics.

Sources

[Building an Information Technology Security Awareness and Training Program \(SP 800-50 Rev. 1\)](#) - NIST, September 2024

[How To Recognize and Avoid Phishing Scams](#) - FTC Consumer Advice, September 2022

[Phishing attacks: defending your organisation](#) - UK NCSC, February 2018 (reviewed February 2024)

[Get started using Attack simulation training \(Defender for Office 365\)](#) - Microsoft Learn, February 2025

[Payloads in Attack simulation training](#) - Microsoft Learn, 2025

[Phishing \(Technique T1566\)](#) - MITRE ATT&CK, 2025.

[Phishing Tests, the Bane of Work Life, Are Getting Meaner](#) - The Wall Street Journal, February 2025

[Improve end-user resilience against QR code phishing](#) - Microsoft Defender for Office 365 Blog, September 2024

TABLE OF CONTENTS

[What is a phishing simulation?](#)

[Design best practices \(cadence, fatigue, comms\)](#)

[How do you create psychological safety?](#)

[What makes a simulation realistic and ethical?](#)

[Which scenarios should you prioritize in 2025?](#)

[How do you choose the “fail method” and design the landing page?](#)

[How do you tailor phishing simulations to your business?](#)

[What metrics](#)

Get more cybersecurity insights like this

- Subscribe to [All Things Human Risk](#) to get a monthly round up of our latest content
- [Request a demo](#) for a customized walkthrough of Hoxhunt

Continue reading

actually prove
behavior change?

How should you
handle repeat
clickers
constructively?

What legal, privacy,
and ethics
guardrails should
you follow?

Phishing simulation
best practices (Top
10)

Year-one rollout:
cadence, difficulty
ramp, and sample
calendar

Templates & topics:
What should you try
vs avoid?

What's the right
platform and tooling
stack?

Why choose
Hoxhunt for
Phishing Training

phishing
simulations?

Case Study: Bird &
Bird transforms
human cyber risk
with Hoxhunt

Phishing simulation
best practices FAQ

Continue reading

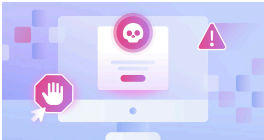
Webinars

SHARE THIS POST

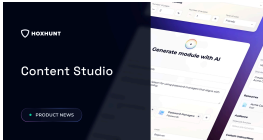
Events

See Hoxhunt in
action

Drastically improve
your security
awareness & phishing
training metrics while



Repeat
Offenders in



Content
Studio creates



The security
awareness

Products

Why Hoxhunt?

Company

Subscribe to All Things Human Risk

Subscribe to our newsletter for
monthly expert insight into current
topics in human-centric
cybersecurity. Drive impact,
accelerate your career, and connect
with forward-thinking cybersecurity
professionals.

your@email.

Subscribe

Hoxhunt needs the contact information you
provide to us to contact you about our
products and services. You may
unsubscribe from these communications at
anytime. For information on how to
unsubscribe, as well as our privacy practices
and commitment to protecting your
privacy, check out our [Privacy Policy](#).



Helsinki

US

Porkkalankatu 3
00180 Helsinki
Finland

+358 20 530 2100

3601 Minnesota
Drive
Suite 900
Minneapolis, MN
55435

automating the
training lifecycle.
Copyright © 2024 Hoxhunt

[Get a Demo](#)